

Отчёт по выполнению 5-ого этапа индивидуального проекта

Дисциплина: Основы информационной безопасности

Верниковская Екатерина Андреевна

Содержание

1	Цель работы	5
2	Задание	6
3	Выполнение 5-ого этапа индивидуального проекта	7
3.1	Выполнение основных действий	7
4	Выводы	21
5	Список литературы	22

Список иллюстраций

3.1	Запуск mysql и apache2	7
3.2	Запуск Burp Suite	8
3.3	Сетевые настройки браузера	8
3.4	Настройки сервера	9
3.5	Настройки Burp Suite	10
3.6	Настройки Proxy	10
3.7	Настройки параметров	11
3.8	Получаемые запросы сервера	11
3.9	Страница авторизации	12
3.10	История запросов	12
3.11	Ввод случайных данных	13
3.12	POST-запрос с вводом пароля и логина	13
3.13	Вкладка Intruder	14
3.14	Изменение типа атаки + специальные символы	15
3.15	1ый Simple list	15
3.16	2ой Simple list	16
3.17	Запуск атаки	16
3.18	Результат запроса (1)	17
3.19	Результат запроса (2)	17
3.20	Дополнительная проверка результата	18
3.21	Вкладка Repeater	18
3.22	Окно Response	19
3.23	html в окне Response	19
3.24	Полученная страница	20

Список таблиц

1 Цель работы

Научиться пользоваться Burp Suite.

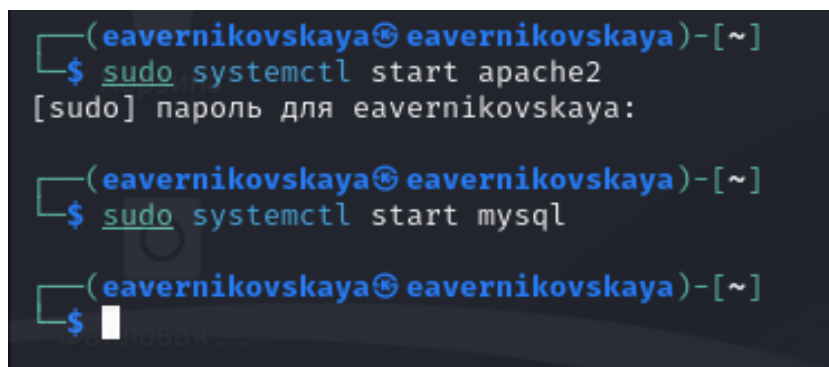
2 Задание

1. Научиться пользоваться Burp Suite. Burp Suite представляет собой набор мощных инструментов безопасности веб-приложений, которые демонстрируют реальные возможности злоумышленника, проникающего в веб-приложения

3 Выполнение 5-ого этапа индивидуального проекта

3.1 Выполнение основных действий

Запустим mysql и apache2: *sudo systemctl start mysql* и *sudo systemctl start apache2*
(рис. 3.1)



```
(eavernikovskaya@eavernikovskaya)-[~]  
$ sudo systemctl start apache2  
[sudo] пароль для eavernikovskaya:  
  
(eavernikovskaya@eavernikovskaya)-[~]  
$ sudo systemctl start mysql  
  
(eavernikovskaya@eavernikovskaya)-[~]  
$
```

Рис. 3.1: Запуск mysql и apache2

Далее запустим Burp Suite (рис. 3.2)

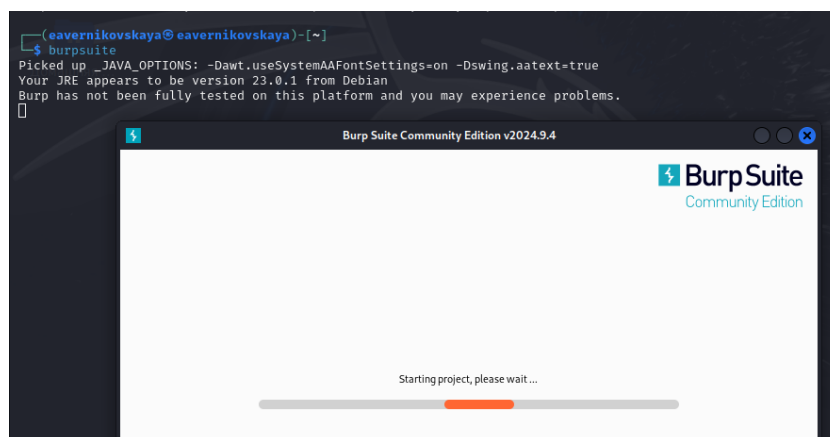


Рис. 3.2: Запуск Burp Suite

Откроем сетевые настройки браузера (рис. 3.3)

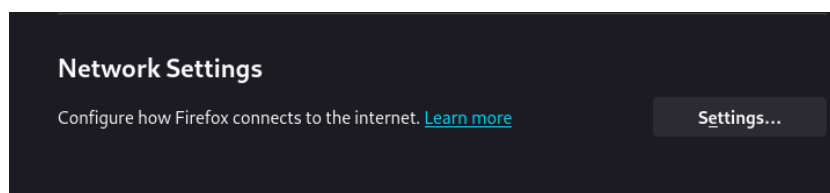


Рис. 3.3: Сетевые настройки браузера

Далее изменим настройки сервера для работы с проху и захватом данных с помощью Burp Suite (рис. 3.4)

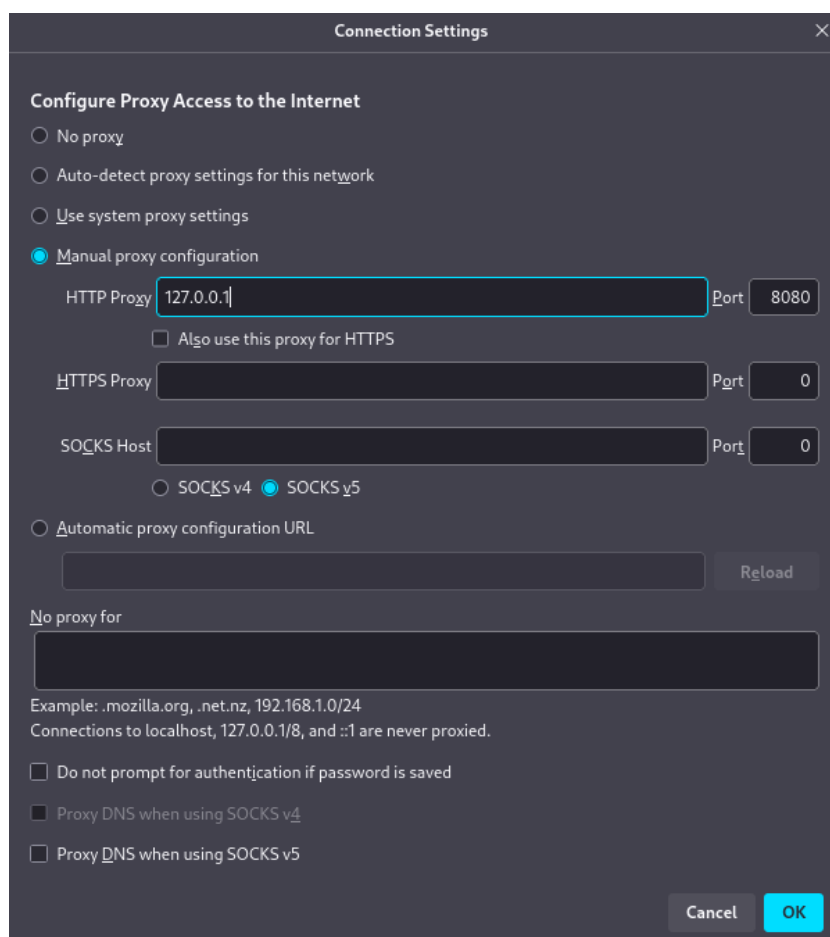


Рис. 3.4: Настройки сервера

Изменим настройки проху инструмента Burp Suite (рис. 3.5)

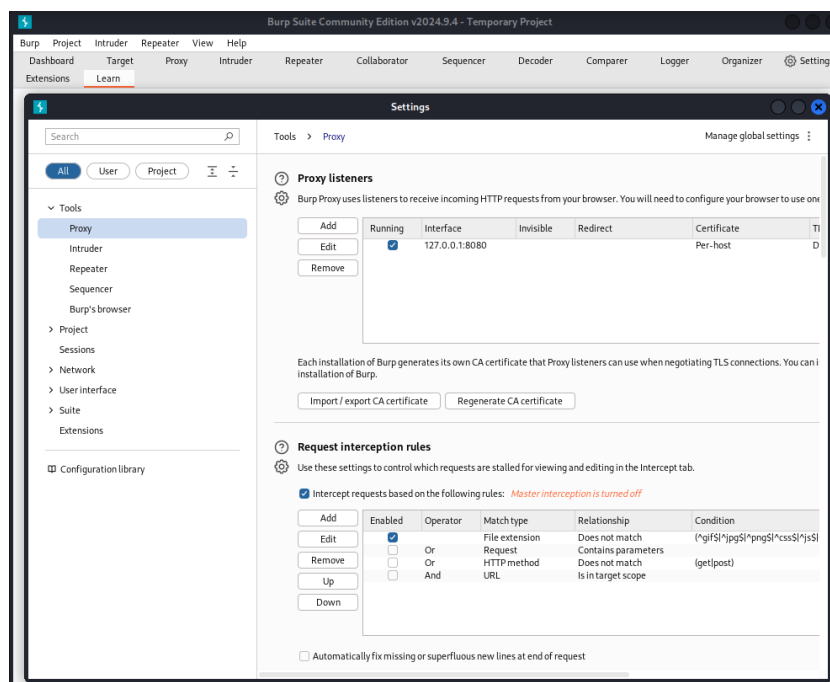


Рис. 3.5: Настройки Burp Suite

Во вкладке Проху установим “Intercept is on” (рис. 3.6)

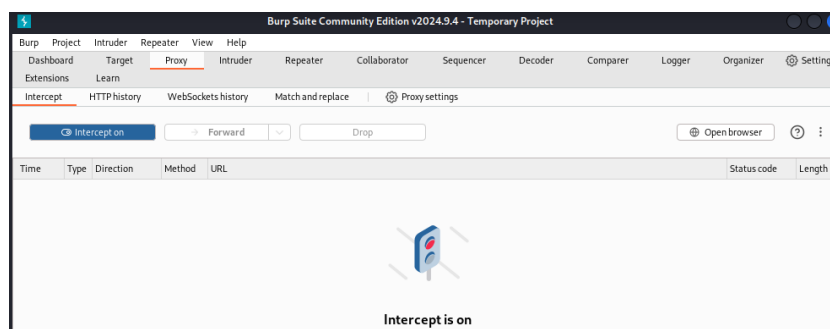


Рис. 3.6: Настройки Проху

Для того чтобы Burp Suite работал исправно с локальным сервером установим параметр `network_allow_hijacking_localhost` на `true` (рис. 3.7)

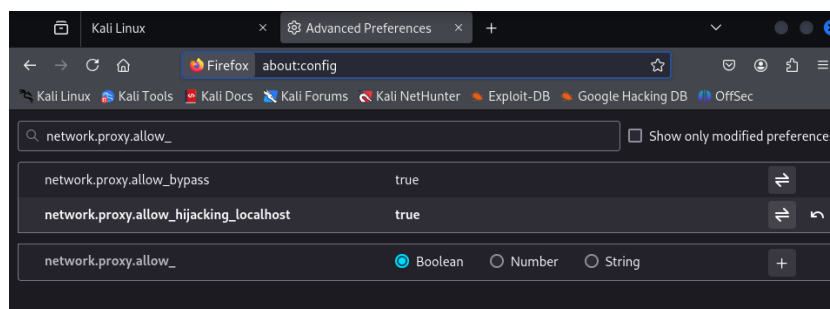


Рис. 3.7: Настройки параметров

Далее попытаемся зайти в браузере на сайт DVWA. Во вкладке Прокси появится захваченный запрос. Нажмём Forward чтобы загрузить страницу (рис. 3.8)

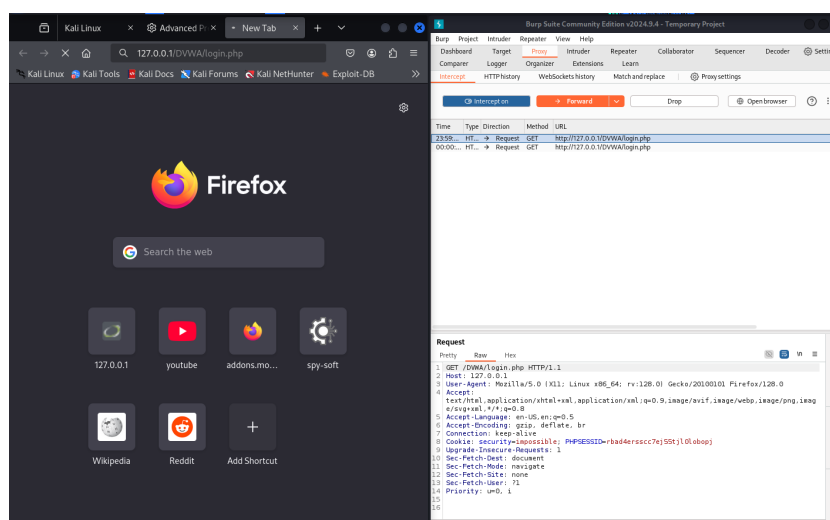


Рис. 3.8: Получаемые запросы сервера

После это загрузится страница авторизации. Текст запроса поменяется (рис. 3.9)

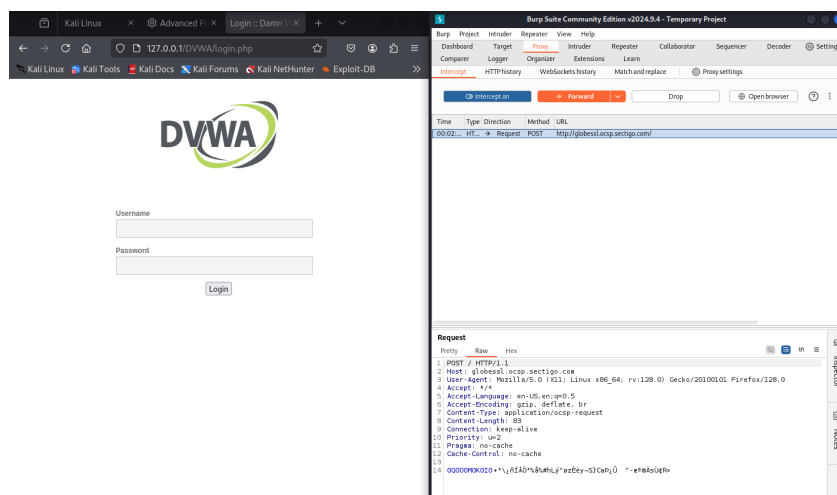


Рис. 3.9: Страница авторизации

История запросов хранится во вкладке Target (рис. 3.10)

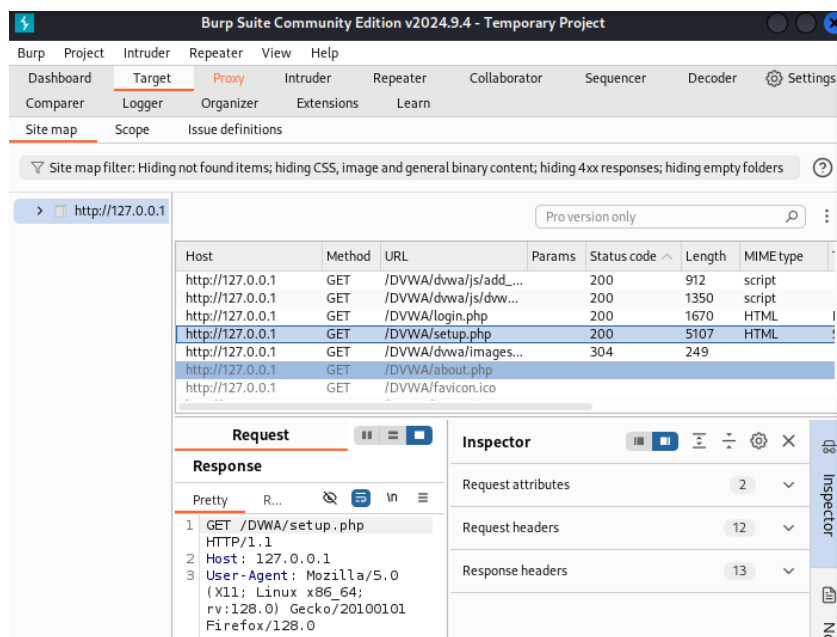


Рис. 3.10: История запросов

Введём неправильные данные в веб-приложение и нажмём на Login. В запросе мы увидим строку, в которой отображаются введенные нами данные (в поле для ввода) (рис. 3.11)

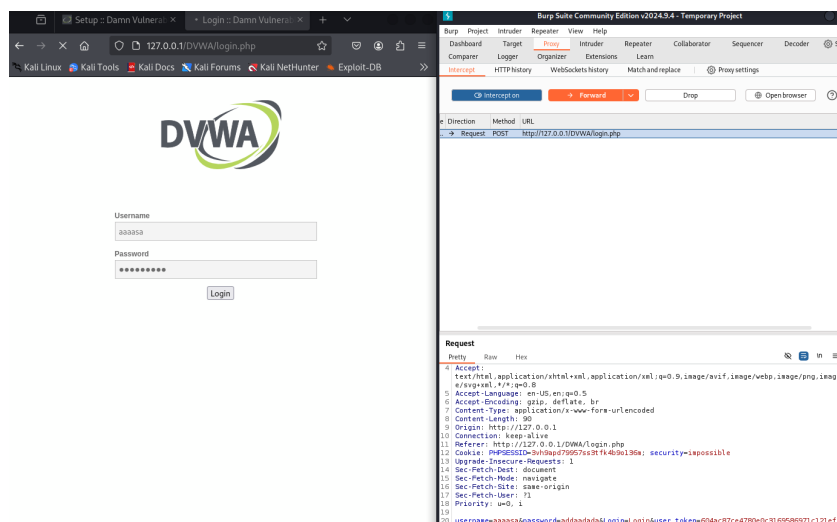


Рис. 3.11: Ввод случайных данных

Этот запас можно найти во вкладке Target. Нажмём правой кнопкой мыши на хост нужного запроса и нажмём Send to Intruder (рис. 3.12)

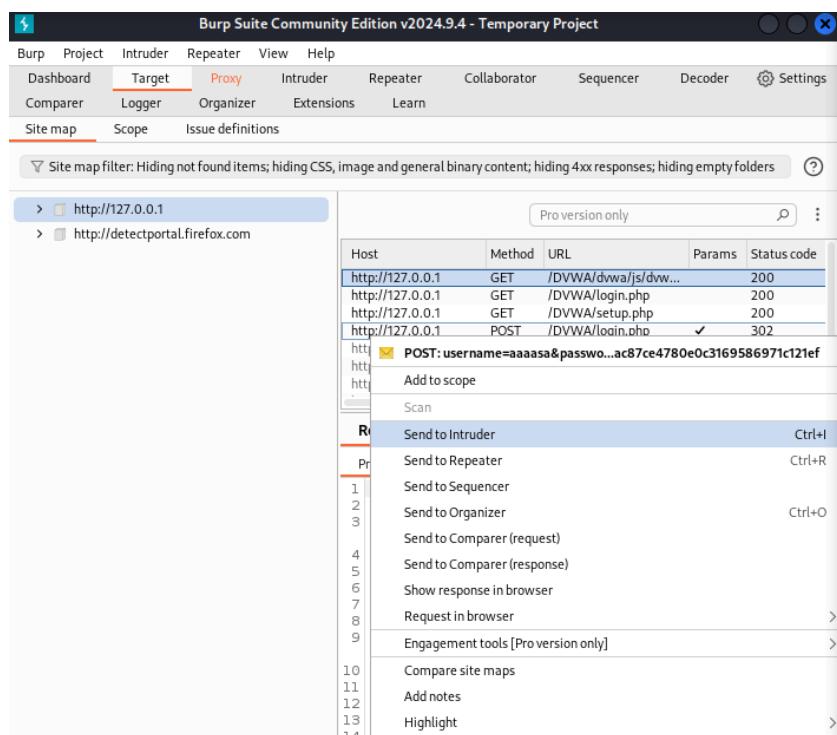


Рис. 3.12: POST-запрос с вводом пароля и логина

Далее переходим на вкладку Intruder. Мы увидим значения по умолчанию у

типа атаки и наш введённый запрос (рис. 3.13)

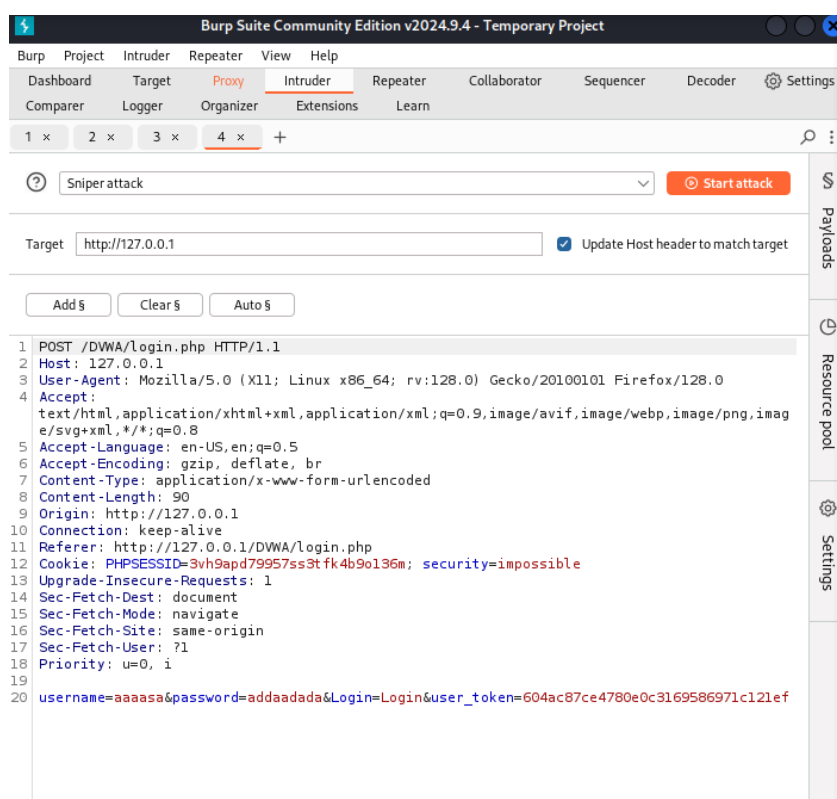


Рис. 3.13: Вкладка Intruder

Изменим значение типа атаки на Cluster bomb attack и проставим специальные символы у тех данных, которые мы будем пробивать (то есть у имени пользователя и пароля) (рис. 3.14)

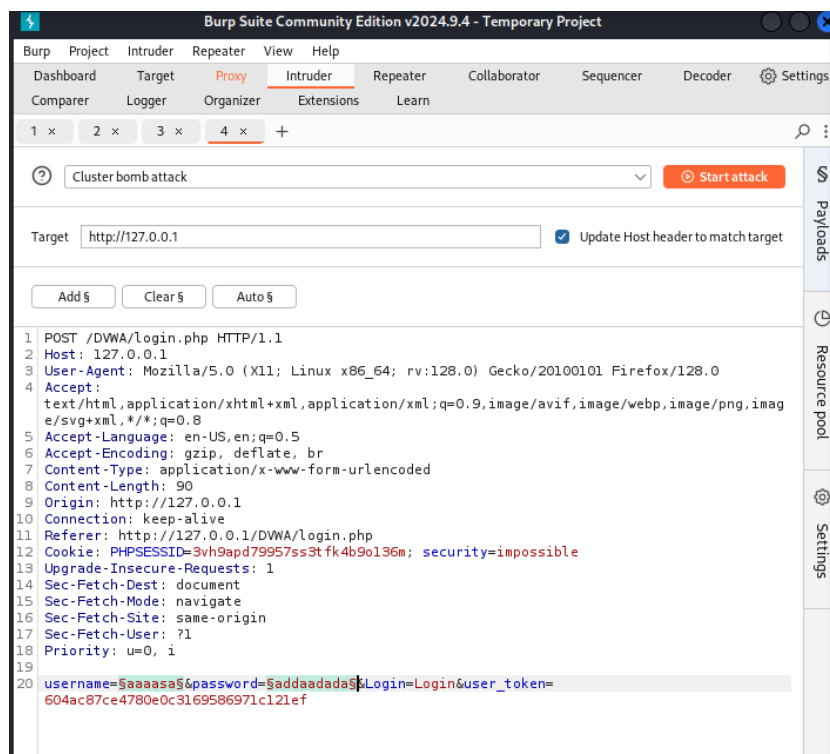


Рис. 3.14: Изменение типа атаки + специальные символы

Так как было отмечено 2 параметра для подбора, то нам нужно 2 списка со значениями для подбора. Далее заполняем 2 списка в Payload settings. В строке request count мы будем видеть нужное количество запросов, чтобы проверить все возможные пары пользователь-пароль (рис. 3.15), (рис. 3.16)

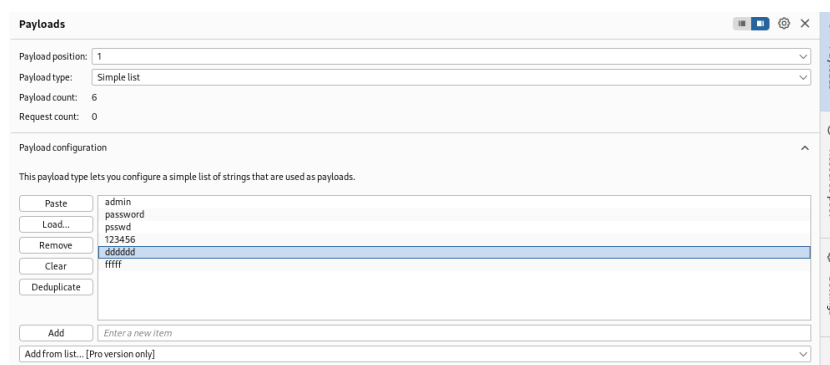


Рис. 3.15: 1ый Simple list

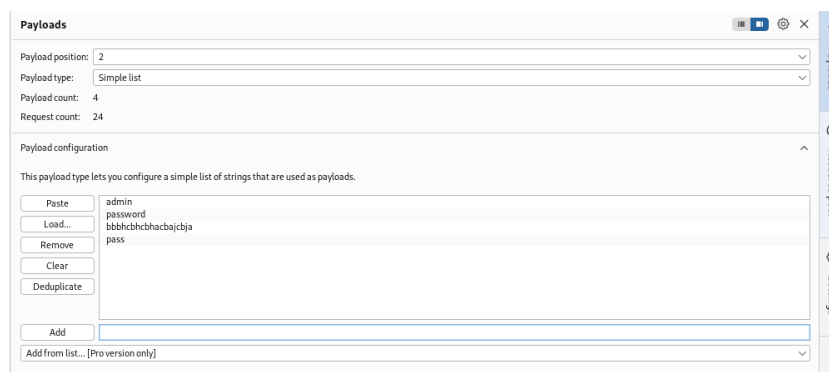


Рис. 3.16: 2ой Simple list

Далее запустим атаку (рис. 3.17)

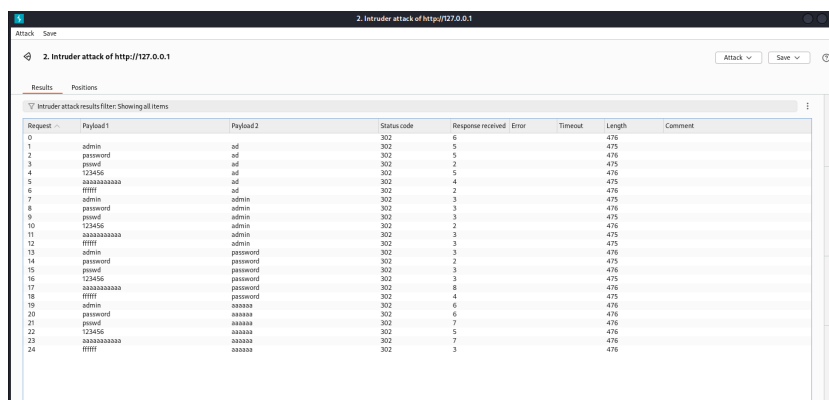


Рис. 3.17: Запуск атаки

При открытии каждого post-запроса можно увидеть полученный get-запрос. В нём видно куда нас перенаправляют после выполнения ввода пары пользователь пароль. На (рис. 3.18) с подбором пары admin-ad видно, что нас перенаправляют на страницу login.php. Это значит что пара не подходит

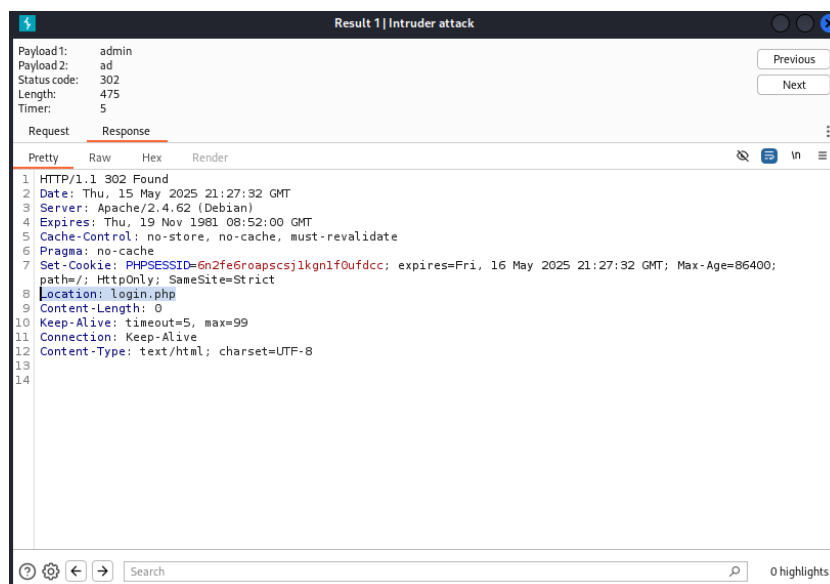


Рис. 3.18: Результат запроса (1)

Далее проверим результат пары sdmin-password. В этом случае нас перенаправляют на страницу index.php. Это значит что пара верная (рис. 3.19)

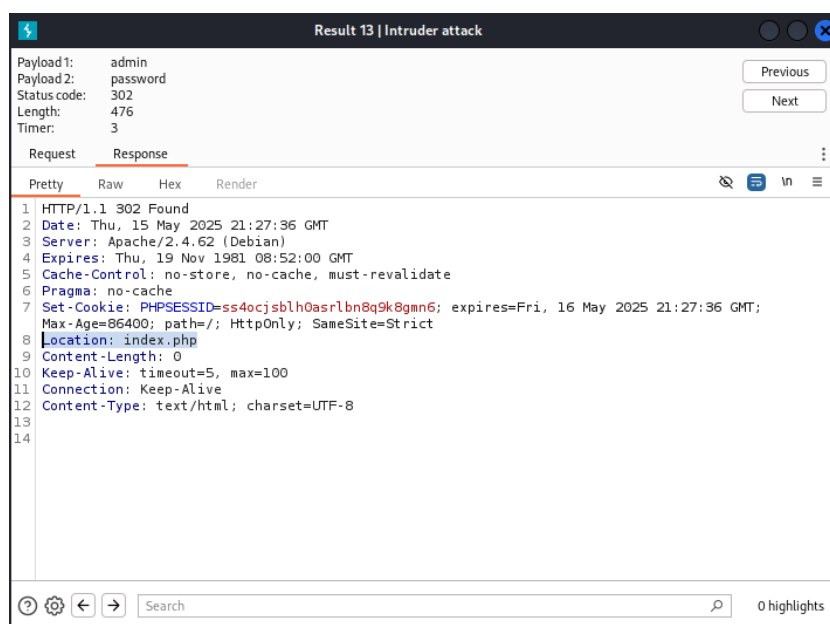


Рис. 3.19: Результат запроса (2)

Также есть дополнительная проверка. Для этого нужно нажать на Send to Repeater (рис. 3.20)

11	aaaaaaaaaaaa	admin
12	ffffff	admin
13	admin	
14	password	
15	psswd	
16	123456	
17	aaaaaaaaaaaa	
18	ffffff	
19	admin	
20	password	
21	psswd	
22	123456	
23	aaaaaaaaaaaa	
24	ffffff	

Result #13

Scan

Send to Intruder Ctrl+I

Send to Repeater Ctrl+R

Send to Sequencer

Send to Organizer Ctrl+O

Send to Comparer (request)

Send to Comparer (response)

Рис. 3.20: Дополнительная проверка результата

Переходим во вкладку Repeater (рис. 3.21)

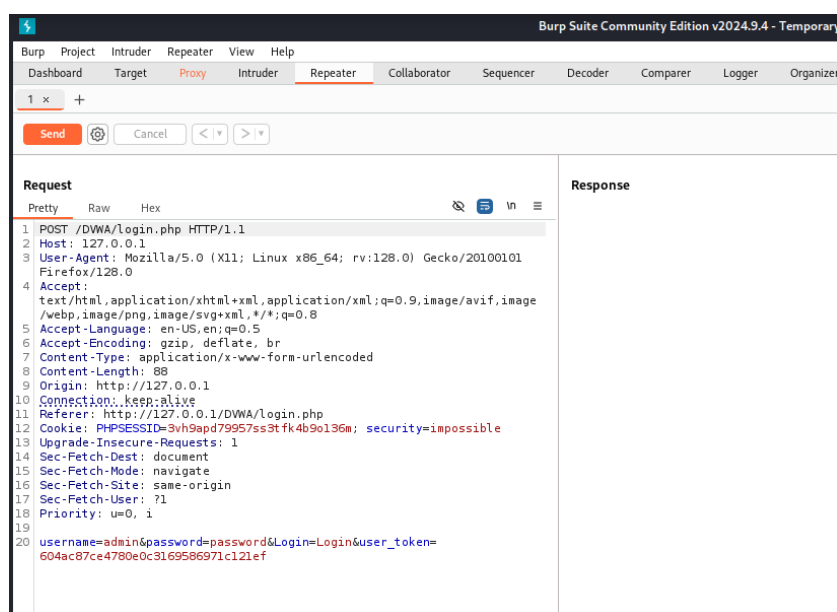


Рис. 3.21: Вкладка Repeater

Нажмём на send. И получим в Response перенаправление на index.php (рис. 3.22)

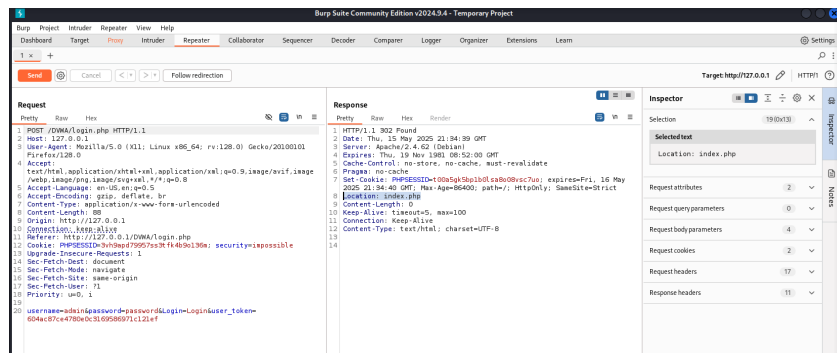


Рис. 3.22: Окно Response

Далее нажмём Follow redirection. После этого мы получим html код в окне Response (подокно Pretty) (рис. 3.23)

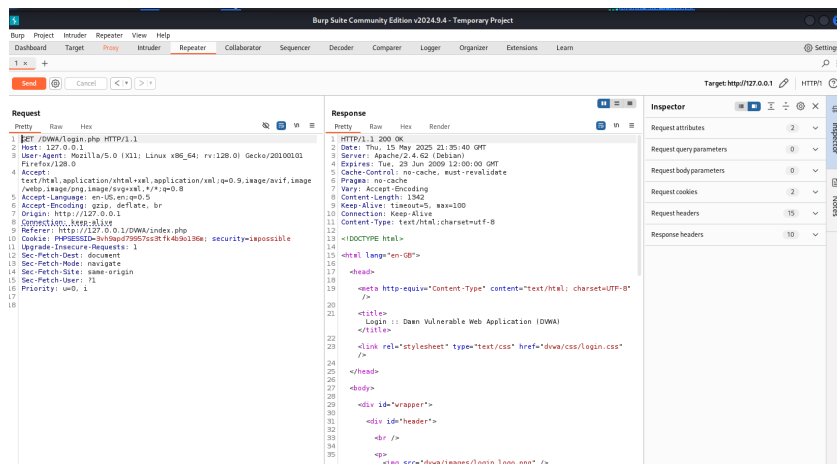


Рис. 3.23: html в окне Response

Далее в подокне Render получим то как выглядит полученная страница (рис. 3.24)

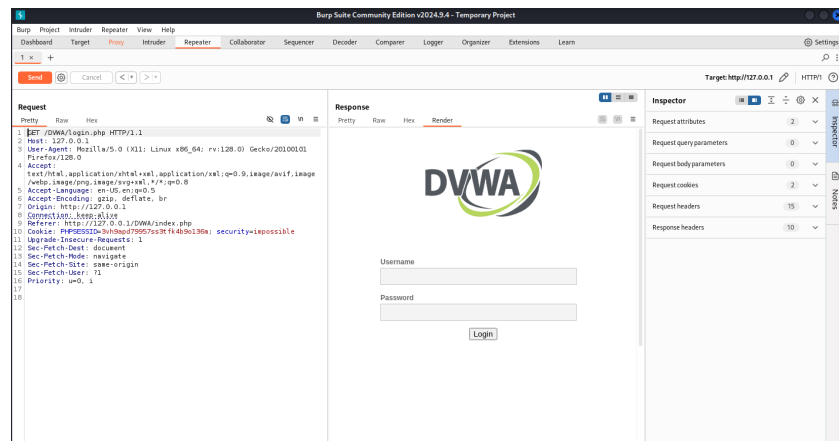


Рис. 3.24: Полученная страница

4 Выводы

В ходе выполнения 5-ого этапа индивидуального проекта мы научились использовать инструмент Burp Suite

5 Список литературы

1. Этапы реализации проекта [Электронный ресурс] URL: <https://esystem.rudn.ru/mod/page/view.php?id=6078>